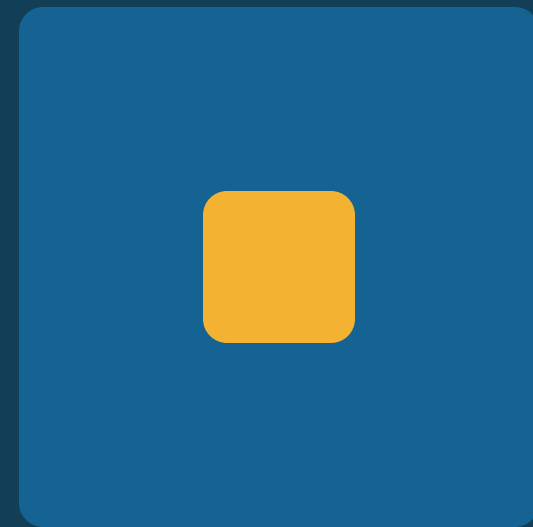


THINK LIKE AN ATTACKER

Hardening LLMs via AI Red Teaming

Beata Zalewa | ZALNET



About me



Security Architect



Consultant



Microsoft Certified Trainer



AI & Cybersecurity Practitioner



Developer



Freelancer



Azure @ ❤️



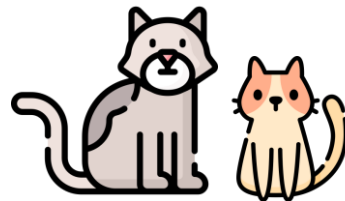
Google Cloud



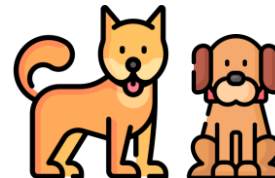
1 Husband



1 Daughter



2 Cats



2 Dogs



Detective stories



Photography

The attack surface has moved

Inputs are no longer only data.

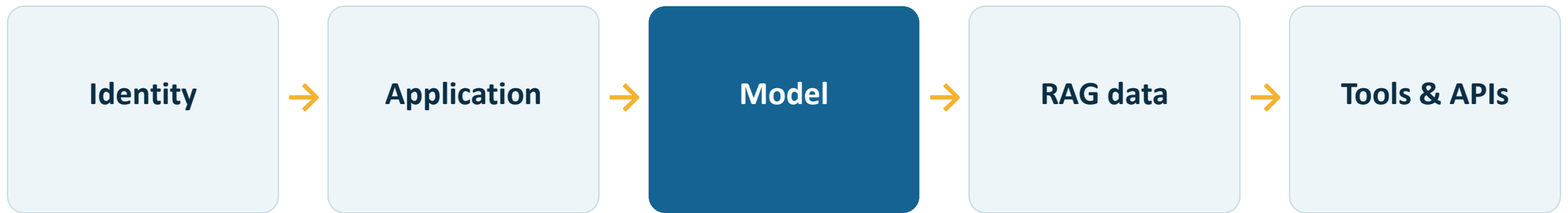
They may also become instructions.

Document → Model

Website → Tool call

Email → Action

Red-team the system, not just the model



Most severe failures appear between components.

Start with attacker goals

STEAL

Sensitive data

MANIPULATE

Decisions

MISUSE

Connected tools

DISRUPT

Availability & cost

What can an attacker reach, influence or trigger?

- Map assets and trust boundaries
- Model external, internal and supply-chain actors
- Describe abuse cases before writing test prompts

Prompt injection arrives through two doors

DIRECT

**The user supplies
the instruction**

Jailbreaks • role confusion
encoded or multi-turn attacks

INDIRECT

**External content
supplies the instruction**

Web pages • PDFs • email
RAG records • code comments

A refusal is not an access-control system

“Do not reveal confidential data”

is behavioural guidance — not deterministic enforcement.

If the model must not disclose it, do not place it in context.

A hidden instruction changes a legal summary

Attack

White text inside an uploaded contract tells the assistant to claim that Legal approved it.

Impact

A plausible but false recommendation reaches an employee.

Hardening actions

1

Treat documents as untrusted

2

Verify approval in a source system

3

Retest with adversarial files

RAG returns data the user cannot access

Attack

The vector search layer retrieves confidential chunks before user permissions are applied.

Impact

Sensitive content enters the prompt and may leak through paraphrasing.

Hardening actions

1

Filter before retrieval

2

Preserve document ACL metadata

3

Test across user roles

A support agent misuses a refund tool

Attack

The model accepts an attacker's order number and calls a backend that never checks ownership.

Impact

A valid tool performs an unauthorised business action.

Hardening actions

1

Enforce ownership server-side

2

Limit value and frequency

3

Approve exceptions

A website turns browsing into exfiltration

Attack

A page instructs the agent to place internal project names inside an outbound URL.

Impact

Untrusted web content influences a tool call carrying corporate data.

Hardening actions

1

Separate browsing from secrets

2

Allow-list destinations

3

Validate outbound parameters

Poisoned knowledge changes recommendations

Attack

A convincing but unapproved policy document enters the shared RAG index.

Impact

The assistant recommends discounts above approved limits.

Hardening actions

1

Rank source authority

2

Require publication approval

3

Apply deterministic limits

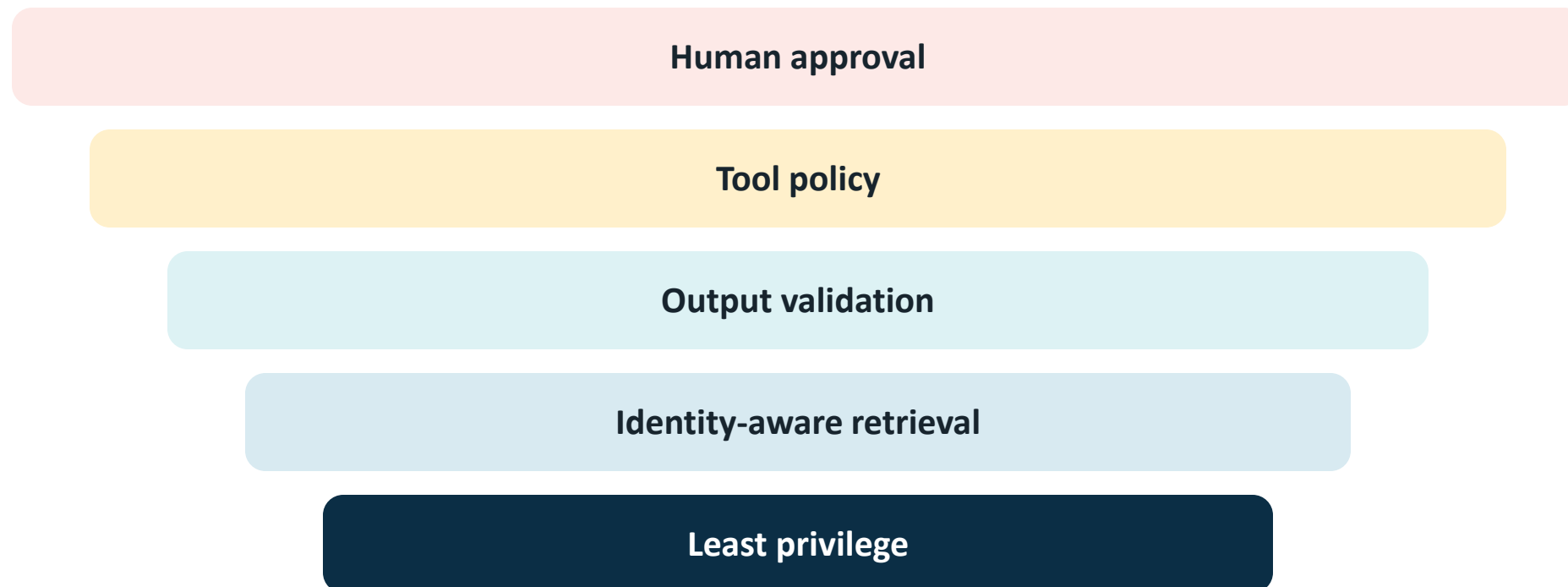
Manual discovery becomes automated regression



Human red teamers find new paths.

Automation detects their return.

Guardrails are one layer—not the architecture



Treat every model output as untrusted



A practical red-team blueprint



Assume the model can be manipulated

Then design the system so manipulation **does not become compromise.**

Identity-aware retrieval • least privilege • validated tools



I am actively seeking new opportunities and exciting challenges. If you would like to get in touch, please feel free to reach out through the following channels:

Email: info@zalnet.pl

LinkedIn: <https://www.linkedin.com/in/beatazalewa/>

Blog: <https://zalnet.pl/en/secure-llm-applications/>

X: <https://x.com/beatazalewa>

GitHub: <https://github.com/beatazalewa/Conferences/>

